Scenario

You are a cybersecurity analyst for yummyrecipesforme.com, a website that sells recipes and cookbooks. A former employee has decided to lure users to a fake website with malware.

The former employee/ hacker executed a brute force attack to gain access to the web host. They repeatedly entered several known default passwords for the administrative account until they correctly guessed the right one. After they obtained the login credentials, they were able to access the admin panel and change the website's source code. They embedded a JavaScript function in the source code that prompted visitors to download and run a file upon visiting the website. After embedding the malware, the hacker changed the password to the administrative account. When customers download the file, they are redirected to a fake version of the website that contains the malware.

Several hours after the attack, multiple customers emailed yummyrecipesforme's helpdesk. They complained that the company's website had prompted them to download a file to access free recipes. The customers claimed that, after running the file, the address of the website changed, and their personal computers began running more slowly.

In response to this incident, the website owner tries to log in to the admin panel but is unable to, so they reach out to the website hosting provider. You and other cybersecurity analysts are tasked with investigating this security event.

To address the incident, you create a sandbox environment to observe suspicious website behavior. You run the network protocol analyzer tcpdump, then type in the URL for the website, yummyrecipesforme.com. As soon as the website loads, you are prompted to download an executable file to update your browser. You accept the download and allow the file to run. You then observe that your browser redirects you to a different URL, greatrecipesforme.com, which contains the malware.

The logs show the following process:

1. The browser initiates a DNS request: It requests the IP address of the yummyrecipesforme.com URL from the DNS server.

2. The DNS replies with the correct IP address.

3. The browser initiates an HTTP request: It requests the yummyrecipesforme.com webpage using the IP address sent by the DNS server.
4. The browser initiates the download of the malware.
5. The browser initiates a DNS request for greatrecipesforme.com.
6. The DNS server responds with the IP address for greatrecipesforme.com.
7. The browser initiates an HTTP request to the IP address for greatrecipesforme.com.

A senior analyst confirms that the website was compromised. The analyst checks the source code for the website. They noticed that java script code had been added to prompt website visitors to download an executable file. Analysis of the downloaded file found a script that redirects the visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com.

The cybersecurity team reports that the web server was impacted by a brute force attack. The disgruntled hacker was able to guess the password easily because the admin password was still set to the default password. Additionally, there were no controls in place to prevent a brute force attack.

Your job is to document the incident in detail, including identifying the network protocols used to establish the connection between the user and the website. You should also recommend a security action to take to prevent brute force attacks in the future.

Security incident report

Section 1: Identify the network protocol involved in the incident
DHCP: Dynamic Host Configuration Protocol Is a network management protocol that assigns unique IP addresses to each device connected to a network. It works with the router to assign IP addresses and provides the addresses of appropriate DNS server and default get away for each device. DHCP Servers use port 67 and clients use port 68 on UDP. DHCP is an application layer protocol of TCP/IP. IP: Internet Protocol is a network communication protocol that addresses and routes data packets at the correct destination as they travel across networks. IP address is assigned by a DHCP server. Internet Protocol is an internet layer protocol of TCP/IP. DNS: Domain Name system protocol is a network communication protocol that translates the internet domain names into IP addresses. For ex: - when a user wishes to access a website a DNS query is sent to a dedicated DNS server and the DNS server replies with the corresponding IP address of that internet domain name. DNS uses port 53 on UDP but when the search exceeds over 512 bytes it uses TCP. DNS is an application layer protocol of TCP/IP. HTTP: Hyper-Text Transfer Protocol is a network communication protocol that is used as a method of communication between servers and clients. HTTP uses port 80, It is a less secure communication method than its new version HTTPS. It is an application layer protocol for TCP/IP.

Section 2: Document of the incident
• A former employee/ hacker has used several known default passwords for the administrative account until they correctly guessed the right one to access website host which is considered a dictionary brute force attack. • After accessing the website host and administrative panel they made changes to the source code of the website and embedded a JavaScript function in the source code that prompted visitors to download and run a file upon visiting the website. • After the issue of malware attack has been reported by users, as a security

analyst I created a sandbox environment to identify the issue. In the sandbox environment the issues that were identified:

1. User tries to access the website yummyrecipesforme.com and the DNS server replies with the corresponding IP address of yummyrecipesforme.com
2. When the user gains access to yummyrecipesforme.com it redirects the user to greatrecipesforme.com. using DNS request and the following website contains downloadable malware that is exploiting user's device and making it run slow.

The conclusion from this analysis is that the DNS server or the client's device is not the issue and the yummyrecipesforme.com is compromised with a JavaScript function that is redirecting the user to greatrecipesforme.com that contains the malware.

Section 3: Recommend one remediation for brute force attacks

Password Policy: yummyrecipesforme.com admin panel should implement password policies such as:

1) No default or commonly used password is not allowed.
2) Password should me minimum 8 characters using (capital later, small letter, integers and symbols)
3) New password must be implemented in 15-30 days